

Room Name: Summit

Date: August 2026

Category: Pyramid of Pain / MITRE

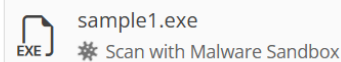
Tools Used: MITRE, Firewall, DNS Filter, Sigma Rule Builder, Hash Filter, Malware Sandbox

Scenario

This simulated scenario involved working with a penetration tester sending you emails with an attachment that has either malware or a clue to malware. The penetration tester will act as an attacker to test the system. Each email is supposed to help you learn the impact of the *Pyramid of Pain* on the attacker.

Investigation

The first email contains an attached file called “sample.exe”.



When scanning this file using the Malware Sandbox, we see the hash values of the file.

MIME	application/x-dosexec
MD5	cbda8ae000aa9cbe7c8b982bae006c2a
SHA1	83d2791ca93e58688598485aa62597c0ebbf7610
SHA256	9c550591a25c6228cb7d74d970d133d75c961ffed2ef7180144859cc09efca8c

This prompts us to use a hash filter/hash detector, which can allow us to block certain hashes.

Manage Hashes

Home / IOC Management / Manage Hashes

Detect Hashes

Manually add a hash to the blocklist

If you've discovered a hash value related to a malicious file or executable, you can submit it here. Submitted hashes will automatically update PicoSecure's EDR detection signatures and improve its ability to detect and block similar threats.

Hash Algorithm:*

- ☐ MD5
☐ SHA1
☐ SHA256

Hash Value:*

Submit Hash

Hash Blocklist

Algorithm	Value	Actions
MD5	c5a20611630c6fd1c2a53fcb00e17	✎ 🗑
MD5	f054bbd2f5ebab9cb5571000b2c50c02	✎ 🗑
SHA1	350930418162cfe2027ab53c99001f0082fed41b	✎ 🗑
SHA256	ed347a07305214ab98974a008674eb78cd03b1fedb73c8be9f79e40fb8e155b0	✎ 🗑
SHA256	b0657d3289bae5be59176613e794ae1bf696c7e2ee529058760fe0b17b0d448f	✎ 🗑
SHA256	cd3c59eedabaa12e1e85068bd687eb23b97aaafd869b9c7b16a96c2e906aa0bf	✎ 🗑

In the hash filter, the hash of the malicious file is entered and blocked, with the hash value entered along with the hash algorithm selected.

block similar threats.

Hash Algorithm:*

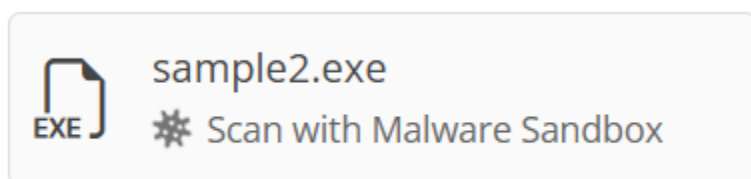
- ☒ MD5
☐ SHA1
☐ SHA256

Hash Value:*

cbda8ae000aa9cbe7c8b982bae006c2a|

Submit Hash

Once the hash is successfully blocked, we move on to the next phase of the attack. The next email gives another malicious file.



When scanning the file, we get more than just hash values this time; we get network activity associated with the file.

Network Activity

HTTP(S) requests

1

TCP/UDP connections

3

DNS requests

0

Threats

0

HTTP requests

PID	Process	Method	IP	URL
1927	sample2.exe	GET	154.35.10.113:4444	http://154.35.10.113:4444/uvLk8Yl32

Connections

PID	Process	IP	Domain	ASN
1927	sample2.exe	154.35.10.113:4444	-	Intrabuzz Hosting Limited
1927	sample2.exe	40.97.128.3:443	-	Microsoft Corporation
1927	sample2.exe	40.97.128.4:443	-	Microsoft Corporation

Hashes can be blocked for the file, but hashes can also be changed by 1 byte, making the blocking of hashed files sometimes ineffective. In the network activity, we do see IP addresses, with 154.35.10.113:4444 worth noting. We even see a GET request with this IP, possibly extracting info. Since 154.35.10.113:4444 is connected to the malicious file, it would make sense to block traffic going out to this IP address as our next course of action.

Firewall Rule Manager

Home / IOC Management / Firewall Rule Manager

Create Firewall Rule

Type:

Source IP:*

Destination IP:*

Action:

Cancel

Save Rule

Under the Firewall Rule Manager, 154.35.10.113 should be blocked with the type set to egress, as this prevents the IP user from extracting any information from the network.

The next email includes another attached file. When scanning the file this time, we also get info on which domain is associated with this file.

DNS requests

Domain	IP
services.microsoft.com	40.97.128.4
emudyn.bresonicz.info	62.123.140.9

Because hashes and IP addresses can be changed easily, this makes blocking sometimes ineffective compared to Domain Names, as they cost money and would be a pain for the attacker to set up if setting

up a brand new domain. emudyn.bresonicz.info is a domain that stands out. Under the DNS Filter, we can block this domain by just typing its name.

DNS Rule Manager

[Home](#) / [IOC Management](#) / [DNS Rule Manager](#)

Create DNS Rule ✕

Rule Name:^{*}

Category:

Malware 

Domain Name^{*}

Action:

Deny 

Denying a domain will automatically include all its subdomains, but denying a subdomain will not automatically include the main domain. Deny rules will take precedence over any preconfigured allow rules.

Cancel

Save Rule

The next email contains another attachment where, this time, the file also contains registry activity.

Registry Activity			
Total events	Read events	Write events	Delete events
3	1	2	0
Modification events			
(PID) Process: (3806) sample4.exe			
Key: HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows Defender\Real-Time Protection			
Operation: write			
Name: DisableRealtimeMonitoring			
Value: 1			
(PID) Process: (1928) explorer.exe			
Key: HKEY_CURRENT_USER\Software\Microsoft\Windows\CurrentVersion\Explorer\Advanced			
Operation: write			
Name: EnableBalloonTips			
Value: 1			
(PID) Process: (9876) notepad.exe			
Key: HKEY_CURRENT_USER\Software\Microsoft\Windows\CurrentVersion\Explorer\FileExts\.txt			
Operation: read			
Name: ProgId			
Value: txtfile			

The process ID associated with the file is 3806.

3806	sample4.exe
------	-------------

When looking at the registry activity, there is one activity that correlates with this PID where the following registry key is modified: HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows Defender\Real-Time Protection. It seems the attacker is performing Defence Evasion, as Real-Time Monitoring is being disabled so the attacker can remain undetected. This prompts us to go to the Sigma Rule Builder > Sysmon Event Logs > Registry Modifications. Here, we enter the registry key, the registry name, and its value, along with the ATT&CK ID for Defense Evasion (T1562).

The next email this time only gives a network log.

2023-08-15 09:23:45	Source: 10.10.15.12	Destination: 43.10.65.115	Port: 443	Size: 21541 bytes
2023-08-15 09:30:00	Source: 10.10.15.12	Destination: 51.102.10.19	Port: 443	Size: 97 bytes
2023-08-15 10:00:00	Source: 10.10.15.12	Destination: 51.102.10.19	Port: 443	Size: 97 bytes
2023-08-15 10:14:21	Source: 10.10.15.12	Destination: 87.32.56.124	Port: 80	Size: 1204 bytes
2023-08-15 10:30:00	Source: 10.10.15.12	Destination: 51.102.10.19	Port: 443	Size: 97 bytes
2023-08-15 11:00:00	Source: 10.10.15.12	Destination: 51.102.10.19	Port: 443	Size: 97 bytes
2023-08-15 11:30:00	Source: 10.10.15.12	Destination: 51.102.10.19	Port: 443	Size: 97 bytes
2023-08-15 11:45:09	Source: 10.10.15.12	Destination: 145.78.90.33	Port: 443	Size: 805 bytes
2023-08-15 12:00:00	Source: 10.10.15.12	Destination: 51.102.10.19	Port: 443	Size: 97 bytes
2023-08-15 12:30:00	Source: 10.10.15.12	Destination: 51.102.10.19	Port: 443	Size: 97 bytes
2023-08-15 13:00:00	Source: 10.10.15.12	Destination: 51.102.10.19	Port: 443	Size: 97 bytes
2023-08-15 13:30:00	Source: 10.10.15.12	Destination: 51.102.10.19	Port: 443	Size: 97 bytes
2023-08-15 13:32:17	Source: 10.10.15.12	Destination: 72.15.61.98	Port: 443	Size: 26084 bytes
2023-08-15 14:00:00	Source: 10.10.15.12	Destination: 51.102.10.19	Port: 443	Size: 97 bytes
2023-08-15 14:30:00	Source: 10.10.15.12	Destination: 51.102.10.19	Port: 443	Size: 97 bytes
2023-08-15 14:55:33	Source: 10.10.15.12	Destination: 208.45.72.16	Port: 443	Size: 45091 bytes
2023-08-15 15:00:00	Source: 10.10.15.12	Destination: 51.102.10.19	Port: 443	Size: 97 bytes
2023-08-15 15:30:00	Source: 10.10.15.12	Destination: 51.102.10.19	Port: 443	Size: 97 bytes
2023-08-15 15:40:10	Source: 10.10.15.12	Destination: 101.55.20.79	Port: 443	Size: 95021 bytes
2023-08-15 16:00:00	Source: 10.10.15.12	Destination: 51.102.10.19	Port: 443	Size: 97 bytes
2023-08-15 16:18:55	Source: 10.10.15.12	Destination: 194.92.18.10	Port: 80	Size: 8004 bytes
2023-08-15 16:30:00	Source: 10.10.15.12	Destination: 51.102.10.19	Port: 443	Size: 97 bytes
2023-08-15 17:00:00	Source: 10.10.15.12	Destination: 51.102.10.19	Port: 443	Size: 97 bytes
2023-08-15 17:09:30	Source: 10.10.15.12	Destination: 77.23.66.214	Port: 443	Size: 9584 bytes
2023-08-15 17:27:42	Source: 10.10.15.12	Destination: 156.29.88.77	Port: 443	Size: 10293 bytes
2023-08-15 17:30:00	Source: 10.10.15.12	Destination: 51.102.10.19	Port: 443	Size: 97 bytes
2023-08-15 18:00:00	Source: 10.10.15.12	Destination: 51.102.10.19	Port: 443	Size: 97 bytes
2023-08-15 18:30:00	Source: 10.10.15.12	Destination: 51.102.10.19	Port: 443	Size: 97 bytes
2023-08-15 19:00:00	Source: 10.10.15.12	Destination: 51.102.10.19	Port: 443	Size: 97 bytes
2023-08-15 19:30:00	Source: 10.10.15.12	Destination: 51.102.10.19	Port: 443	Size: 97 bytes
2023-08-15 20:00:00	Source: 10.10.15.12	Destination: 51.102.10.19	Port: 443	Size: 97 bytes

When observing closely, we can see that most of the logs have a size of 97 bytes going to 51.102.10.19, but every 30-minute interval, there is an abnormal size, possibly indicating malware. This prompts us to go to the Sigma Rule Builder > Sysmon Event Logs > Network Connections, where we detect any network connections made from a host machine every 30 minutes (1800 seconds). The logs imply that the communication is part of a connection to a remote host to get instructions, AKA Command & Control (TA0011).

Step 3: Network Connections

Set the rule conditions and options:

This rule will detect network connections made from a host machine with specific conditions, such as remote IP, port, size of the connection, and how often it occurs (frequency).

Remote IP:*	Any
Remote Port:*	Any
Size (bytes):*	97
Frequency (seconds):*	1800
ATT&CK ID:*	Command and Control (TA0011)

At PicoSecure, we require that all Sysmon detection rules map to the [MITRE ATT&CK framework](#). This ensures that our SOC team has the context to facilitate a more effective threat detection, analysis, and response.

Cancel	Validate Rule
---------------------------------------	--

In the final email, we get another log; however, this time it seems to be some commands.

```
dir c:\ >> %temp%\exfiltr8.log
dir "c:\Documents and Settings" >> %temp%\exfiltr8.log
dir "c:\Program Files\" >> %temp%\exfiltr8.log
dir d:\ >> %temp%\exfiltr8.log
net localgroup administrator >> %temp%\exfiltr8.log
ver >> %temp%\exfiltr8.log
systeminfo >> %temp%\exfiltr8.log
ipconfig /all >> %temp%\exfiltr8.log
netstat -ano >> %temp%\exfiltr8.log
net start >> %temp%\exfiltr8.log
```

When looking at MITRE (<https://attack.mitre.org/techniques/T1020/>), this seems to be an Automated Exfiltration technique (T1020). These commands seem to create and modify a file. This prompts us to go to the Sigma Rule Builder > Sysmon Event Logs > File Creation and Modification, where we can block this file from being created or modified.

Step 3: File Creation and Modification

Set the rule conditions and options:

File Path:*	%temp%
File Name:*	exfiltr8.log
ATT&CK ID:*	Exfiltration (TA0010)

As a Discreet user, we require that all Sigma detection rules must be the MITRE ATT&CK framework.

MITRE Summary Table:

Stage	Technique	ID	Detection Method
Hash blocking	Indicator Removal	T1070	Hash filter
IP blocking	Command & Control	TA0011	Egress firewall rule
Domain blocking	C2 Infrastructure	T1583	DNS filter
Registry modification	Defense Evasion	T1562.001	Sigma rule
Network beaconing	Command & Control	TA0011	Sigma rule
File exfiltration	Automated Exfiltration	T1020	Sigma rule

Key Takeaways:

- The Pyramid of Pain is crucial when it comes to securing systems, as knowing what techniques the attacker uses and what will annoy them will prevent frequent attacks.
- MITRE is an amazing framework that provides knowledge on techniques, groups, tactics, tools, and more. This will help give an idea of what to protect against.
- Identifying the ATT&CK type will give a major advantage, as it will provide the motivation, giving a clear picture of what is at risk